# Laboratorio 2

*Plataforma de análisis y gestión de riesgos*

Asignatura de Análisis y Gestión de Riesgos · Duración de la sesión 100 minutos

## Descripción y objetivo

Construiréis una aplicación web para identificar, evaluar y comunicar riesgos de una organización ficticia. El resultado debe ayudar a la dirección a entender qué puede ocurrir, qué objetivos se verían afectados y qué medidas conviene priorizar. Las propuestas deberán ser suficientemente concretas para orientar su implementación técnica.

Utilizaréis una IA como consultor y asistente de desarrollo. La aplicación publicada funcionará sin IA integrada. Trabajaremos por etapas, con una estructura y reglas comunes; podréis decidir el diseño y justificar vuestras medidas de protección.

## Requisitos antes de la sesión

| Recurso | Preparación necesaria |
|---|---|
| Portátil y conexión | Equipo con cargador, navegador actualizado, conexión a Internet y permiso para guardar archivos del proyecto. |
| IA de desarrollo | Acceso a Cowork u otra herramienta capaz de generar archivos. Con un chat convencional, incorporaréis manualmente los cambios al proyecto. |
| GitHub | Cuenta activa y posibilidad de crear un repositorio privado y conceder acceso al profesor. |
| Vercel | Cuenta activa y autorización para importar el repositorio. Utilizaremos despliegues Preview. |
| Git | Disponible en el entorno desde el que versionaréis y subiréis el proyecto. Comprobad la autenticación antes de clase. |
| Node.js y npm | Disponibles en el entorno de construcción, con una versión compatible con la plantilla. No es necesario duplicarlos en Windows si trabajáis en Linux. |
| Bitwarden | Cuenta activa para custodiar las credenciales del proyecto. No compartáis la contraseña maestra ni la bóveda personal. |
| Base de datos | Acceso al proveedor indicado por el profesor, o al servicio previsto en la plantilla. Revisad los límites del plan elegido. |
| Docker y Vaultwarden | Opcionales para la ampliación local. Si elegís esta vía, preparad Docker antes de la sesión. No son necesarios para el recorrido con Vercel y Bitwarden. |

Las instalaciones y las altas de servicios deben quedar resueltas antes de comenzar. No introduzcáis contraseñas o tokens en el chat para resolver la autenticación.

## Caso de trabajo

Una academia ficticia gestiona matrículas mediante una plataforma web. Su objetivo es completar las solicitudes dentro del plazo establecido y conservar la información necesaria para prestar el servicio. El profesor proporcionará el caso, los activos y las condiciones conocidas. Solo se usarán datos ficticios.

## Funciones obligatorias

- Describir brevemente la organización, el proceso y el objetivo analizado.
- Registrar al menos dos riesgos con una formulación guiada.
- Evaluar probabilidad e impacto y justificar los valores asignados.
- Mostrar el nivel de riesgo calculado según las reglas comunes.
- Asociar una medida concreta, su prioridad y la forma de comprobar su eficacia.
- Ofrecer un resumen comprensible para dirección y acceso al detalle técnico.
- Guardar los registros y recuperarlos después de recargar la página.
- Proteger el acceso a los registros y las operaciones de escritura.
- Publicar una versión operativa en Vercel y mantener el proyecto en Git.

## Cómo formular el riesgo

Utilizad esta ayuda de redacción y revisad que los elementos formen un escenario coherente:

Debido a [condición o debilidad], podría producirse [evento asociado a una amenaza] en [activo o proceso], causando [consecuencia] y dificultando [objetivo de la organización].

Ejemplo: debido a que las copias no se han probado, un fallo de la base de datos podría interrumpir la plataforma de matrícula y dificultar la recuperación de solicitudes, impidiendo completar la admisión en plazo.

Distinguid las condiciones conocidas de los supuestos. Un término técnico como «fallo de la base de datos» debe acompañarse de su consecuencia para el servicio y el objetivo.

## Evaluación y propuesta de protección

Se utilizarán escalas didácticas de probabilidad e impacto de 1 a 3, con los descriptores entregados por el profesor. La puntuación será probabilidad × impacto: bajo de 1 a 2, medio de 3 a 4 y alto de 6 a 9. Son reglas del ejercicio, no una fórmula atribuida al ENS o a NIST.

Justificad qué medida recomendaríais primero, qué efecto esperáis y cómo comprobaríais que funciona. Una medida propuesta no reduce automáticamente el riesgo: será necesario implantarla y verificarla antes de revisar la valoración.

## Seguridad y uso de la documentación

El proyecto incorporará requisitos académicos apoyados en el ENS y NIST SP 800-53 Rev. 5. Cada requisito tendrá una implementación prevista, una prueba y una evidencia. Esta selección no acredita conformidad completa con ninguno de los marcos.

| ID | Requisito comprobable |
|---|---|
| SEG 01 | Ausencia de secretos reales en archivos e historial de Git. |
| SEG 02 | Los secretos del servidor no se envían al navegador ni aparecen en respuestas o registros. |
| SEG 03 | El servidor comprueba la autorización antes de modificar datos. |
| SEG 04 | La cuenta de base de datos utiliza los permisos necesarios para su función. |
| SEG 05 | El servidor valida tipos, longitudes y valores permitidos. |
| SEG 06 | Desarrollo, Preview y producción separan la configuración y los datos. |
| SEG 07 | Los errores públicos no revelan credenciales ni detalles internos sensibles. |
| SEG 08 | La entrega identifica los cambios, las pruebas y la versión desplegada. |

## Gestión de las credenciales

Bitwarden sirve para custodiar credenciales. Los valores necesarios para ejecutar la aplicación se configuran en un archivo local excluido de Git o en las variables de entorno de Vercel. Guardar una contraseña en Bitwarden no configura automáticamente la aplicación.

El repositorio incluirá una plantilla .env.example sin valores reales y documentación de la finalidad, lugar de uso y sustitución de cada secreto. Las credenciales administrativas deben separarse de las que usa la aplicación. Si se expone una credencial, revocadla o cambiadla; borrarla del último archivo no elimina la exposición.

## Documentación mínima del repositorio

- README.md con objetivo, ejecución, despliegue y forma de comprobar la entrega.
- docs/fuentes.md con enlaces oficiales, versiones consultadas y condiciones de reutilización.
- docs/requisitos-seguridad.md con requisitos, referencias verificadas y pruebas de aceptación.
- Documentación de escalas, gestión de secretos, resultados de pruebas y despliegue, sin valores sensibles.

## Normas de realización

No carguéis datos personales, documentación empresarial real, credenciales ni material restringido en la IA. Usad las fuentes autorizadas y verificad las referencias propuestas por el asistente. Conservad una decisión de la IA que hayáis revisado o corregido. Las pruebas se harán únicamente sobre vuestro proyecto y dentro del alcance autorizado.

Los resúmenes de normas se redactarán con palabras propias. No redistribuyáis documentos completos sin comprobar sus condiciones de uso.

## Secuencia de la sesión

| Minutos | Actividad |
|---|---|
| 0 a 10 | Lectura del alcance y demostración del resultado esperado. |
| 10 a 25 | Estructura del proyecto, Git y requisitos de seguridad. |
| 25 a 40 | Formulación y evaluación de los dos riesgos. |
| 40 a 65 | Desarrollo sobre la plantilla y configuración de secretos. |
| 65 a 80 | Comprobaciones funcionales y técnicas. |
| 80 a 90 | Publicación y comprobación de la URL Preview. |
| 90 a 100 | Entrega y justificación de la medida prioritaria. |

El profesor marcará los puntos de parada. Antes de continuar, comprobad el resultado, revisad los cambios generados por la IA y guardad una versión en Git. Los despliegues se realizarán en los hitos indicados.

## Entrega y evaluación

- URL operativa de Vercel y acceso del profesor al repositorio, que puede mantenerse privado.
- Identificador del commit correspondiente a la entrega y dos riesgos completos.
- Resultados de las pruebas de persistencia, clasificación, validación y escritura no autorizada.
- Evidencias de configuración del despliegue sin valores de secretos y una decisión revisada de la IA.

Se evaluará la claridad de los riesgos para dirección, la justificación de su evaluación, la utilidad de las medidas y el funcionamiento de la aplicación. La revisión técnica analizará el código, el historial y las pruebas, junto con las evidencias del despliegue. No entreguéis contraseñas personales ni archivos con secretos.

Pregunta de cierre: si dirección solo pudiera aprobar una de vuestras medidas, ¿cuál recomendaríais primero y cómo comprobaríais que protege el objetivo afectado?

## Ampliaciones valorables

Una vez cubiertos los requisitos obligatorios, podéis añadir filtros, exportación CSV, gráficos, seguimiento de medidas o un entorno local con Docker y Vaultwarden. Se valorarán por su utilidad, funcionamiento y seguridad. No sustituyen requisitos obligatorios ni se exige completarlas en la sesión.

## Fuentes oficiales de referencia

ENS · Real Decreto 311/2022, anexo II. Selección orientativa: op.acc.4, op.exp.2 y mp.sw.1.
https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191

NIST SP 800-53 Rev. 5 · Selección orientativa: IA-5, AC-6 y SI-10.
https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

Condiciones de uso de publicaciones NIST
https://www.nist.gov/open/copyright-fair-use-and-licensing-statements-srd-data-software-and-technical-series-publications

**Soporte Prompts parte 1- Requisitos Aplicación Riesgos**

1.-

Vamos a construir paso a paso una aplicación web para una práctica de análisis y gestión de riesgos.

La aplicación permitirá registrar riesgos de una organización ficticia, evaluarlos y presentar medidas de protección comprensibles para dirección. Se publicará en Vercel y funcionará sin IA integrada.

En esta primera tarea:

1. Comprueba si puedes acceder a la carpeta de trabajo seleccionada.
2. Comprueba si tienes disponibles Git, Node.js y npm, e indica sus versiones. Si tu entorno está aislado del equipo Windows, explica dónde realizas esas comprobaciones; no supongas que las herramientas también están instaladas en Windows.
3. Crea únicamente un archivo README.md con el título «Laboratorio de gestión de riesgos» y una descripción breve del objetivo.
4. No instales herramientas ni dependencias y no crees todavía la aplicación.
5. No leas archivos de credenciales, contraseñas ni variables de entorno existentes.

Al terminar, indica la ubicación del archivo creado, el resultado de las comprobaciones y cualquier limitación que debamos resolver antes de continuar.

2.-

Vamos a construir la aplicación por etapas y consultar sus avances mediante despliegues Preview de Vercel.

En la carpeta compartida:

1. Crea una aplicación mínima con Next.js y TypeScript, compatible con Vercel. Puedes instalar las dependencias necesarias en tu entorno Linux.
2. Crea una página en español con:
    - Título: «Laboratorio de gestión de riesgos».
    - Descripción: «Identificar, evaluar y comunicar riesgos para priorizar medidas de protección».
    - Aviso: «Caso académico con datos ficticios».
3. No añadas todavía base de datos, autenticación ni servicios de IA.
4. Prepara .gitignore para excluir dependencias, archivos generados, configuración local de Vercel y archivos de variables de entorno. Permite conservar una futura plantilla .env.example sin secretos.
5. Actualiza README.md con las instrucciones de construcción y el objetivo del proyecto.
6. Comprueba que la aplicación se construye correctamente.
7. Si la carpeta no pertenece ya a un repositorio Git, inicialízalo. No modifiques un repositorio existente sin explicarme antes su ubicación.
8. No conectes cuentas ni publiques todavía.

Al terminar, indica qué has creado, el resultado de la construcción y cómo subir estos archivos a un repositorio privado de GitHub. No solicites contraseñas ni tokens en el chat.

3.-

Trabaja sobre el proyecto existente en C:\dev\USJ\Laboratorio2.

Ahora vamos a incorporar las referencias y los requisitos de seguridad. No añadas funcionalidades ni cambies las dependencias.

1. Crea docs/fuentes.md utilizando estas fuentes oficiales:
    - ENS: https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191
    - NIST SP 800-53 Rev. 5: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
    - Condiciones de uso de NIST: https://www.nist.gov/open/copyright-fair-use-and-licensing-statements-srd-data-software-and-technical-series-publications
      Registra título, revisión o versión consultada, fecha de consulta, enlace y apartados utilizados. Redacta resúmenes propios, sin copiar documentos completos. No inventes referencias; si no puedes verificarlas, indícalo.
2. Crea docs/requisitos-seguridad.md con estos requisitos académicos:
    - SEG-01: secretos fuera del código y del historial de Git.
    - SEG-02: secretos de servidor ausentes del código enviado al navegador, respuestas y registros.
    - SEG-03: autorización en el servidor para modificar datos.
    - SEG-04: mínimo privilegio para la cuenta de base de datos.
    - SEG-05: validación de entradas en el servidor.
    - SEG-06: separación de configuración y datos entre desarrollo, Preview y producción.
    - SEG-07: errores sin credenciales ni detalles internos sensibles.
    - SEG-08: trazabilidad entre cambios, pruebas y despliegues.
      Para cada requisito incluye:
    - Finalidad.
    - Referencia concreta, cuando se haya verificado.
    - Implementación prevista.
    - Prueba de aceptación.
    - Evidencia esperada.
    - Estado inicial: pendiente.
      Utiliza como referencias orientativas ENS op.acc.4, op.exp.2 y mp.sw.1; y NIST IA-5, AC-6 y SI-10. No fuerces asociaciones: distingue los requisitos propios del laboratorio de los derivados de una referencia.
3. Explica que esta selección es una adaptación didáctica y no acredita conformidad completa con ENS o NIST.
4. Actualiza README.md con enlaces a ambos documentos.
5. Revisa que los nuevos archivos no contienen secretos y crea un commit con el mensaje: "Documenta fuentes y requisitos de seguridad"

No publiques ni solicites credenciales. Al terminar, muestra el resumen de requisitos y señala las decisiones que siguen pendientes.

4.-

Vamos a publicar la aplicación existente en Vercel mediante un despliegue Preview, sin conectar todavía GitHub.

1. Trabaja sobre el proyecto Laboratorio2. Si necesitas una copia en Linux, verifica que corresponde exactamente a los archivos y al commit del proyecto compartido.
2. Comprueba que no se incluirán archivos de secretos ni archivos innecesarios en la subida. Verifica también que .vercel queda excluido de Git.
3. Utiliza la CLI oficial de Vercel. Puedes instalarla en tu entorno si es necesario, sin cambiar las dependencias de la aplicación.
4. Inicia la autenticación oficial y dame las instrucciones para completarla personalmente en el navegador. No solicites contraseñas ni tokens en el chat y no muestres credenciales internas.
5. Tras autenticarme, crea o vincula un proyecto llamado laboratorio2-riesgos en mi cuenta, con Next.js y configuración estándar.
6. Publica únicamente en Preview, sin utilizar --prod.
7. Comprueba la página publicada y sus tres textos.
8. Registra en docs/despliegue.md la URL, la fecha, el commit de origen y el resultado de la comprobación, sin secretos.

Si tu entorno no permite completar la autenticación, detente en ese punto y explica cómo continuar desde mi equipo. No uses un token como alternativa sin que lo hayamos acordado.

Al terminar, dame la URL y confirma que el despliegue pertenece al entorno Preview.

5.-

Vamos a incorporar el contexto del ejercicio a la aplicación existente.

1. Crea docs/caso.md con este caso ficticio:
   La Academia Horizonte gestiona matrículas mediante una plataforma web. La campaña dura siete días. Su objetivo es que las solicitudes puedan completarse dentro del plazo y que los registros confirmados se conserven y puedan recuperarse.
   Activos: plataforma web, base de datos de matrículas y copias de seguridad.
   Condiciones conocidas:
   - Hay una única instancia de base de datos y no se ha probado la restauración de las copias.
   - La cuenta que utiliza la aplicación tiene permisos administrativos sobre la base de datos.
     Estas condiciones pertenecen al caso ficticio. No describen la configuración real de nuestro proyecto.
2. Crea docs/evaluacion-riesgos.md con estas reglas didácticas:
   Horizonte: la próxima campaña de matrícula.
   Probabilidad:
   - 1 Baja: existen razones justificadas para considerar poco probable el evento.
   - 2 Media: el evento es plausible y las condiciones disponibles no permiten considerarlo poco probable.
   - 3 Alta: hay indicios concretos de que el evento es probable durante la campaña.
     Impacto:
   - 1 Menor: incidencia limitada, sin comprometer el plazo ni perder registros confirmados.
   - 2 Significativo: interrupción o trabajo de recuperación relevante, pero el objetivo todavía puede alcanzarse.
   - 3 Grave: impide completar solicitudes en plazo o provoca pérdida no recuperable de registros confirmados.
     Puntuación: probabilidad × impacto.
     Clasificación: bajo 1–2, medio 3–4 y alto 6–9.
     Cada valoración exige una justificación. La falta de información se registra como supuesto o información pendiente, sin convertirse automáticamente en probabilidad alta.
     Estas reglas pertenecen al laboratorio; no se atribuyen a ENS ni a NIST.
3. Añade debajo de la cabecera de la web:
   - Una sección «Organización y objetivo».
   - Una sección «Condiciones del caso».
   - Una sección desplegable «Cómo evaluaremos los riesgos», con las escalas y clasificación.
   - Una aclaración visible de que las condiciones son ficticias.
4. Enlaza los documentos desde README.md.
5. Comprueba la construcción, guarda un commit llamado «Define caso y reglas de evaluación» y publica otro despliegue Preview en el mismo proyecto de Vercel.

No añadas todavía formularios, base de datos ni autenticación. No cambies dependencias salvo que exista una necesidad concreta y explicada.

Al terminar, indica la URL Preview, el commit y las comprobaciones realizadas.

laboratorio2-riesgos-mvvt6ezad-usj5.vercel.app

Caso académico con datos ficticios

# Laboratorio de gestión de riesgos

Identificar, evaluar y comunicar riesgos para priorizar medidas de protección

**Condiciones ficticias.** La organización y las condiciones que se describen a continuación pertenecen a un caso inventado para la práctica. No describen la configuración real de este proyecto ni de ninguna organización existente.

## Organización y objetivo

La **Academia Horizonte** gestiona matrículas mediante una plataforma web. La campaña dura **siete días**.

Su objetivo es que:

- las solicitudes puedan completarse dentro del plazo, y
- los registros confirmados se conserven y puedan recuperarse.

**Activos:** plataforma web, base de datos de matrículas y copias de seguridad.

## Condiciones del caso

- Hay una única instancia de base de datos y no se ha probado la restauración de las copias.
- La cuenta que utiliza la aplicación tiene permisos administrativos sobre la base de datos.

▾ **Cómo evaluaremos los riesgos**

6.-

Añade a la aplicación una sección «Identificar un riesgo», después del contexto y las reglas de evaluación.

En esta etapa construiremos un formulario y una vista previa. No añadiremos todavía evaluación, base de datos ni autenticación.

1. Organiza el formulario en cuatro bloques con ayudas breves:

A. Qué queremos proteger

- Proceso o servicio.
- Activo afectado: plataforma web, base de datos o copias de seguridad.
- Objetivo afectado: completar solicitudes en plazo o conservar y recuperar registros.

B. Qué podría ocurrir y por qué

- Condición o debilidad conocida.
- Amenaza: qué podría provocar daño.
- Evento: qué sucedería concretamente.

C. Qué consecuencias tendría

- Consecuencia para la organización.

D. Qué estamos suponiendo

- Supuestos o información pendiente, opcional.

2. Añade una ayuda que distinga los conceptos:
   - Debilidad: facilita que ocurra el daño.
   - Amenaza: puede provocar el daño.
   - Evento: lo que sucede.
   - Consecuencia: el efecto sobre la actividad y sus objetivos.
3. Muestra una vista previa que reúna los datos siguiendo esta estructura:
   «Debido a [condición], [amenaza] podría provocar [evento] sobre [activo], causando [consecuencia] y afectando al objetivo de [objetivo], en el proceso de [proceso]».

No muestres campos vacíos como si el enunciado estuviera completo. Indica qué falta y aclara que la persona debe revisar la coherencia de la frase.

4. Incorpora un botón «Cargar ejemplo» con este escenario:
   - Proceso: matrícula.
   - Activo: base de datos.
   - Objetivo: conservar y recuperar registros.
   - Condición: no se ha probado la restauración de las copias.
   - Amenaza: fallo del almacenamiento.
   - Evento: pérdida de acceso a los registros confirmados.
   - Consecuencia: imposibilidad de reconstruir parte de las matrículas.
   - Supuesto: se desconoce si las copias disponibles permiten recuperar todos los registros.
5. Incluye «Limpiar formulario». Los datos permanecerán únicamente en memoria mientras la página esté abierta. Muestra claramente: «Borrador temporal. No se guarda al recargar».

6. Usa etiquetas accesibles, límites razonables de longitud y mensajes claros. Trata los textos como texto plano, sin interpretarlos como HTML.
7. Documenta los campos y comprobaciones en docs/formulacion-riesgo.md. La validación del navegador es provisional: no marques SEG-05 como cumplido, porque todavía falta validación en el servidor.
8. Comprueba que se puede cargar el ejemplo, editarlo, detectar campos incompletos y limpiar el formulario. Comprueba la construcción y publica un nuevo Preview.

Guarda un commit llamado «Añade formulación guiada del riesgo». Devuelve la URL, el commit y los resultados de las comprobaciones.